

# NECCDC 2026 — Runbook 2 of 3

Windows POS Hardening After Redeployment

IP: 10.100.6.37 — Harden immediately on redeployment.

---

Covers: First steps after redeployment, firewall lockdown, domain join hardening, Teleport compromise scenarios, lateral movement prevention, and ongoing monitoring.

## Phase 0 — Immediately After Redeployment

The Black Team redeploys the POS to a pre-competition state. The moment you get RDP access, Red Team may already be scanning it. You have minutes before it gets compromised again if you do not act immediately.

■ Do NOT join this machine to the domain until you have completed Phase 1 firewall lockdown. Joining an unhardened machine to the domain gives Red Team a foothold back into AD the moment it connects.

### 0.1 — Verify You Are On the Right Machine

```
hostname
ipconfig /all
# Confirm IP is 10.100.6.37
# Note the subnet mask and gateway for firewall rules
```

### 0.2 — Change All Local Passwords Immediately

```
# Change local Administrator password before anything else
net user Administrator NewStr0ngP@ss2026!

# List all local accounts
Get-LocalUser | Select Name, Enabled, LastLogon

# Disable any local accounts you do not recognize
Disable-LocalUser -Name 'suspiciousaccount'

# Remove from local admins if not needed
Remove-LocalGroupMember -Group 'Administrators' -Member 'username'
```

## Phase 1 — Firewall Lockdown (Before Domain Join)

This is the most important phase. Lock down what can reach this machine and what it can reach before connecting it to anything.

### 1.1 — Enable and Verify Firewall Profiles

```
# Confirm all profiles are ON
Get-NetFirewallProfile | Select Name, Enabled, DefaultInboundAction

# Enable all profiles
Set-NetFirewallProfile -Profile Domain,Private,Public `
  -Enabled True `
  -DefaultInboundAction Block
```

■ Setting DefaultInboundAction to Block means ONLY explicitly allowed ports will accept connections. Do this before domain join then open only what is needed.

### 1.2 — Allow Only Required Inbound Ports

```
# Allow RDP only from DC IP (your team's access)
New-NetFirewallRule -DisplayName 'Allow RDP from DC' `
  -Direction Inbound -Protocol TCP -LocalPort 3389 `
  -RemoteAddress 10.100.6.64 -Action Allow

# Allow DC to manage this machine (WinRM)
New-NetFirewallRule -DisplayName 'Allow WinRM from DC' `
  -Direction Inbound -Protocol TCP -LocalPort 5985,5986 `
  -RemoteAddress 10.100.6.64 -Action Allow

# Allow ICMP ping from DC only
New-NetFirewallRule -DisplayName 'Allow Ping from DC' `
  -Direction Inbound -Protocol ICMPv4 `
  -RemoteAddress 10.100.6.64 -Action Allow
```

### 1.3 — Block Dangerous Outbound Paths

```
# Block RDP outbound (POS should never RDP to other machines)
New-NetFirewallRule -DisplayName 'Block RDP Outbound' `
  -Direction Outbound -Protocol TCP -RemotePort 3389 -Action Block

# Block WinRM outbound (POS should not remote-manage other machines)
New-NetFirewallRule -DisplayName 'Block WinRM Outbound' `
  -Direction Outbound -Protocol TCP -RemotePort 5985,5986 -Action Block

# Block SMB outbound to anything except DC (no lateral SMB movement)
New-NetFirewallRule -DisplayName 'Block SMB Lateral' `
  -Direction Outbound -Protocol TCP -RemotePort 445 -Action Block

# Re-allow SMB to DC only (needed for GPO)
New-NetFirewallRule -DisplayName 'Allow SMB to DC' `
  -Direction Outbound -Protocol TCP -RemotePort 445 `
  -RemoteAddress 10.100.6.64 -Action Allow

# Block internet access entirely
New-NetFirewallRule -DisplayName 'Block Internet Outbound' `
```

```
-Direction Outbound -RemoteAddress Internet -Action Block
```

## 1.4 — Block Specific Attack Ports

```
New-NetFirewallRule -DisplayName 'Block Telnet' `
  -Direction Inbound -Protocol TCP -LocalPort 23 -Action Block

New-NetFirewallRule -DisplayName 'Block FTP' `
  -Direction Inbound -Protocol TCP -LocalPort 21 -Action Block

Set-SmbServerConfiguration -EnableSMB1Protocol $false -Force

# Disable NetBIOS over TCP
$adapters = Get-WmiObject Win32_NetworkAdapterConfiguration
foreach ($a in $adapters) { $a.SetTcpipNetbios(2) }
```

## Phase 2 — Service Hardening on the POS

---

### 2.1 — Disable All Unnecessary Services

```
# Print Spooler
Stop-Service Spooler -Force
Set-Service Spooler -StartupType Disabled

# Remote Registry
Stop-Service RemoteRegistry -Force
Set-Service RemoteRegistry -StartupType Disabled

# Fax
Stop-Service Fax -Force
Set-Service Fax -StartupType Disabled

# IIS (POS is not a web server)
Stop-Service W3SVC -Force -ErrorAction SilentlyContinue
Set-Service W3SVC -StartupType Disabled -ErrorAction SilentlyContinue

# Windows Search (unnecessary on POS)
Stop-Service WSearch -Force -ErrorAction SilentlyContinue
Set-Service WSearch -StartupType Disabled -ErrorAction SilentlyContinue

# Disable PowerShell v2
Disable-WindowsOptionalFeature -Online `
-FeatureName MicrosoftWindowsPowerShellV2Root
```

### 2.2 — Check What Is Listening

```
# See all listening ports and the process behind them
netstat -ano | findstr LISTENING

# Map PID to process name
Get-Process | Select Id, ProcessName | Sort Id
```

#### *What If: Unexpected port is listening*

```
# Find which service owns the port
Get-NetTCPConnection -State Listen |
  Where-Object {$_ .LocalPort -eq } |
  ForEach-Object {
    $proc = Get-Process -Id $_.OwningProcess
    [PSCustomObject]@{Port=$_ .LocalPort; PID=$_.OwningProcess; Process=$proc.Name}
  }

# Kill the process if confirmed malicious
Stop-Process -Id -Force
```

## Phase 3 — Teleport Compromise Scenarios

Teleport is the remote access gateway for this environment. If Red Team compromises Teleport, they have a privileged path into every machine that Teleport manages — including the POS. Here is how to detect and respond to each scenario.

### 3.1 — Detect if Teleport Has Been Compromised

```
# Check if Teleport service is running
Get-Service teleport -ErrorAction SilentlyContinue

# Check Teleport config for rogue nodes or users
# Teleport config is typically at C:\ProgramData\Teleport
Get-Content 'C:\ProgramData\Teleport\teleport.yaml' -ErrorAction SilentlyContinue

# Check for unexpected outbound connections from Teleport process
Get-NetTCPConnection -State Established |
  Where-Object {$_.OwningProcess -eq (Get-Process teleport).Id} |
  Select LocalAddress, LocalPort, RemoteAddress, RemotePort
```

### 3.2 — Scenario: Teleport Is Down / Unreachable

If Teleport goes down, you lose your remote access channel. This is why RDP must stay open to the DC IP specifically.

```
# Verify RDP is still open as backup access
Get-NetFirewallRule -DisplayName 'Allow RDP from DC' | Select Enabled

# If Teleport is down, check if it was deliberately stopped
Get-EventLog -LogName System -Source 'Service Control Manager' `
  -Newest 50 | Where-Object {$_.Message -like '*teleport*'}
```

#### *What If: Teleport was stopped by Red Team*

```
# Attempt restart
Start-Service teleport

# If service is missing entirely, check binary
Test-Path 'C:\Program Files\Teleport\teleport.exe'

# Submit Black Team ticket if binary is gone
# @BlackTeam Teleport binary missing from POS at 10.100.6.37
```

### 3.3 — Scenario: Teleport Certificate or Token Compromised

■ If Red Team has a valid Teleport token or certificate, they have authenticated access to everything Teleport manages. Rotate tokens immediately.

```
# Teleport tokens are managed from the Teleport Auth server
# You need access to the Teleport admin console or CLI
# tctl is the Teleport admin tool

# List active tokens
tctl tokens ls

# Delete all existing join tokens
tctl tokens rm
```

```
# Generate new token
tctl tokens add --type=node --ttl=1h
```

### 3.4 — Scenario: Teleport Used to Pivot to POS

Red Team uses a compromised Teleport session to get onto the POS, then pivots to the domain. Signs to look for:

```
# Check for unexpected sessions on the POS
query session
query user

# Check recent logon events
Get-WinEvent -FilterHashtable @{
    LogName='Security'; Id=4624
    StartTime=(Get-Date).AddHours(-1)
} | Select TimeCreated, Message | Format-List

# Look for Teleport process spawning cmd or PowerShell
Get-WmiObject Win32_Process |
    Where-Object {$_.ParentProcessId -eq (Get-Process teleport -EA SilentlyContinue).Id} |
    Select Name, ProcessId, CommandLine
```

#### ***What If: Active Red Team session detected on POS***

```
# Kill the session
logoff

# Block the source IP immediately
New-NetFirewallRule -DisplayName "Block RT Session $(Get-Date -Format HHmm)" `
    -Direction Inbound `
    -RemoteAddress `
    -Action Block

# Screenshot everything for IR report first
```

## Phase 4 — Domain Join Hardening

Only join the domain after firewall lockdown is complete. Once joined, additional GPO-based restrictions apply automatically if your DC GPOs are configured correctly.

### 4.1 — Join the Domain Securely

```
# Join domain
Add-Computer -DomainName 'chefops.local' `
  -Credential (Get-Credential) `
  -OUPath 'OU=POS_Terminals,DC=chefops,DC=local' `
  -Restart

# Verify after restart
(Get-WmiObject Win32_ComputerSystem).Domain
```

■ Specify the OU path so the POS lands in the POS\_Terminals OU and gets the correct restrictive GPO applied immediately.

### 4.2 — Verify GPO Applied After Join

```
# Run after domain join and restart
gpresult /r /scope computer
gpresult /r /scope user

# Force policy refresh
gpupdate /force
```

### 4.3 — Restrict Local Admin Rights via GPO

From the DC, ensure the POS OU has a Restricted Groups GPO that controls exactly who is in the local Administrators group on the POS machine.

```
# From DC - check what GPOs are linked to POS OU
Get-GPInheritance -Target 'OU=POS_Terminals,DC=chefops,DC=local' |
  Select -ExpandProperty InheritedGpoLinks | Select DisplayName, Order
```

### 4.4 — Dedicated POS Service Account

```
# Create dedicated POS account on DC with minimal rights
New-ADUser -Name 'pos-svc' `
  -SamAccountName 'pos-svc' `
  -UserPrincipalName 'pos-svc@chefops.local' `
  -Path 'OU=ChefOps_ServiceAccounts,DC=chefops,DC=local' `
  -AccountPassword (ConvertTo-SecureString 'P0sSvc!S3cure2026' -AsPlainText -Force) `
  -Enabled $true `
  -PasswordNeverExpires $true `
  -CannotChangePassword $true

# Verify it has NO privileged group memberships
Get-ADUser 'pos-svc' -Properties MemberOf | Select -ExpandProperty MemberOf
```



# Phase 5 — Ongoing Monitoring

## 5.1 — Check Every 30 Minutes

```
# Active sessions
query user

# Listening ports - anything new?
netstat -ano | findstr LISTENING

# Recent logon events
Get-WinEvent -FilterHashtable @{
  LogName='Security'; Id=@(4624,4625,4648)
  StartTime=(Get-Date).AddMinutes(-30)
} | Select TimeCreated, Id, Message | Format-List
```

## 5.2 — Watch for Re-Compromise Signs

| Sign                              | What It Means                         | Action                     |
|-----------------------------------|---------------------------------------|----------------------------|
| New process from unknown parent   | Process execution — possible backdoor | Kill process, block IP, IR |
| New listening port appeared       | Backdoor installed                    | Identify process, kill, IR |
| Outbound connection to unknown IP | Command / data exfil                  | Block IP, IR immediately   |
| Local admin account appeared      | Persistence planted                   | Disable account, IR        |
| Teleport spawning cmd.exe         | Active Red Team session               | Kill session, block IP     |

## 5.3 — Quick Persistence Recheck After Each Interval

```
Get-ScheduledTask |
  Where-Object {$_.TaskPath -notlike '\Microsoft\*'} |
  Select TaskName, TaskPath

Get-WMIObject -Namespace root\subscription -Class __EventFilter

Get-LocalGroupMember -Group 'Administrators'

Get-WinEvent -FilterHashtable @{
  LogName='Security'; Id=4720
  StartTime=(Get-Date).AddMinutes(-30)
} -ErrorAction SilentlyContinue
```